Modulus Calculation

1. **$3^{-1}\ mod\ 26$**

Answer:

Normal Method:

$$3^{-1}\ mod\ 26 = \frac{1}{3}\ mod\ 26$$
$$= \frac{1 + 26 \times k}{3}\ mod\ 26$$
$$= \frac{27}{3}\ mod\ 26 \quad [\text{For } k = 1]$$
$$= 9\ mod\ 26$$
$$= 9$$

Extended Euclidian Formula:

$$3\ \begin{vmatrix}26\\ \underline{24}\end{vmatrix}\ \underset{(q_1)}{8} \qquad 2\ \begin{vmatrix}3\\ \underline{2}\end{vmatrix}\ \underset{(q_2)}{1} \qquad 1\ \begin{vmatrix}2\\ \underline{2}\end{vmatrix}\ 2$$
$$2 \qquad\qquad 1 \qquad\qquad 0$$

Here,

$$w_0 = 1$$
$$w_1 = -q_1 w_0 = -8 \times 1 = -8$$
$$w_2 = w_0 - q_2 w_1 = 1 - 1 \times (-8) = 9$$

$$\therefore 3^{-1}\ mod\ 26 = 9$$

2. **$5^{-1}\ mod\ 13$**

Answer:

Normal Method:

$$5^{-1}\ mod\ 13 = \frac{1}{5}\ mod\ 13$$
$$= \frac{1 + 13 \times k}{5}\ mod\ 13$$
$$= \frac{40}{5}\ mod\ 13 \quad [\text{For } k = 3]$$
$$= 8\ mod\ 13$$
$$= 8$$

Extended Euclidian Formula:

$$5\ \begin{vmatrix}13\\ \underline{10}\end{vmatrix}\ \underset{(q_1)}{2} \qquad 3\ \begin{vmatrix}5\\ 3\end{vmatrix}\ \underset{(q_2)}{1} \qquad 2\ \begin{vmatrix}3\\ \underline{2}\end{vmatrix}\ \underset{(q_3)}{1} \qquad 1\ \begin{vmatrix}2\\ \underline{2}\end{vmatrix}\ 2$$
$$3 \qquad\qquad 2 \qquad\qquad 1 \qquad\qquad 0$$

Here,

$$w_0 = 1$$
$$w_1 = -q_1 w_0 = -2 \times 1 = -2$$
$$w_2 = w_0 - q_2 w_1 = 1 - 1 \times (-2) = 3$$
$$w_3 = w_1 - q_3 w_2 = -2 - 1 \times (3) = -5$$

$$-5 = -5\ mod\ 13$$
$$= 13\ mod\ 13 - 5\ mod\ 13$$
$$= (13 - 5)\ mod\ 13$$
$$= 8\ mod\ 13$$
$$= 8$$

$$\therefore 5^{-1}\ mod\ 13 = 8$$

3. $\mathbf{7^{-1}\ mod\ 160}$

Answer:

Normal Method:

$$
\begin{aligned}
7^{-1}\ mod\ 160 &= \frac{1}{7}\ mod\ 160 \\
&= \frac{1+160\times k}{7}\ mod\ 160 \\
&= \frac{161}{7}\ mod\ 160 \quad [\text{For } k=1] \\
&= 23\ mod\ 160 \\
&= 23
\end{aligned}
$$

Extended Euclidian Formula:

$$
\begin{array}{ccccc}
7 \left|\begin{array}{c}160\\ \underline{154}\end{array}\right| 22 & & 6 \left|\begin{array}{c}7\\ \underline{6}\end{array}\right| 1 & & 1 \left|\begin{array}{c}6\\ \underline{6}\end{array}\right| 6 \\
\quad (q_1) & & \quad (q_2) & & \\
6 & & 1 & & 0
\end{array}
$$

Here,

$$w_0 = 1$$
$$w_1 = -q_1 w_0 = -22 \times 1 = -22$$
$$w_2 = w_0 - q_2 w_1 = 1 - 1 \times (-22) = 23$$

$$\therefore 7^{-1}\ mod\ 160 = 23$$

4. $\mathbf{3^{10}\ mod\ 13}$

Answer:

$$
\begin{aligned}
3^{10}\ mod\ 13 &= (3^3\ mod\ 13)^2 \times 3\ mod\ 13 \\
&= 1^2\ mod\ 13 \times 3\ mod\ 13 \\
&= (1\times 3)\ mod\ 13 \\
&= 3
\end{aligned}
$$

5. $\mathbf{7^{100}\ mod\ 13}$

Answer:

$$
\begin{aligned}
7^{100}\ mod\ 13 &= (7^2\ mod\ 13)^{50} \\
&= 10^{50}\ mod\ 13 \\
&= (10^2\ mod\ 13)^{25} \\
&= 9^{25}\ mod\ 13 \\
&= (9^2\ mod\ 13)^{12} \times 9\ mod\ 13 \\
&= 3^{12}\ mod\ 13 \times 9\ mod\ 13 \\
&= 1\ mod\ 13 \times 9\ mod\ 13 \quad [\boldsymbol{a^{p-1}\ mod\ p = 1}] \\
&= (1\times 9)\ mod\ 13 \\
&= 9
\end{aligned}
$$

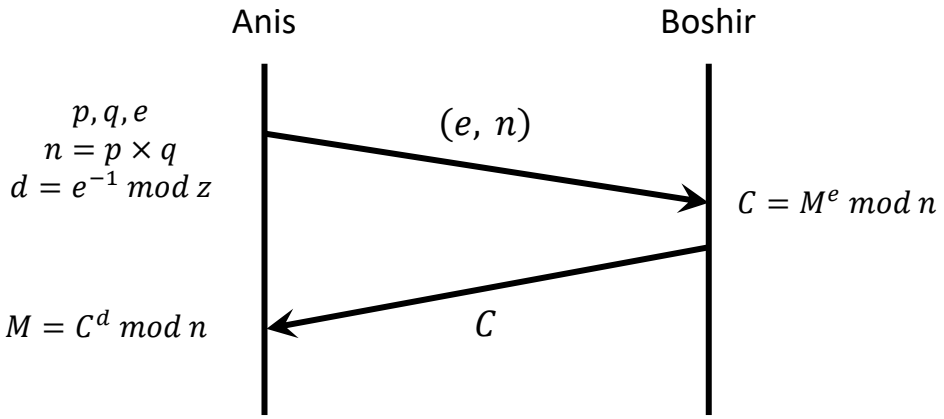
Nahin's theorem:

$$
\begin{aligned}
7^{100}\ mod\ 13 &= (7^{12}\ mod\ 13)^8 \times 7^4\ mod\ 13 \\
&= 1^8 \times 7^4\ mod\ 13 \quad [\boldsymbol{a^{p-1}\ mod\ p = 1}] \\
&= 1 \times 9\ mod\ 13 \\
&= 9
\end{aligned}
$$

- p একটি মৌলিক সংখ্যা (prime number) হয়।
- a, p দ্বারা বিভাজ্য না হয়, অর্থাৎ $a\ mod\ p \neq 0$

RSA Encryption / Decryption

1. **Boshir wants to send a message M to Anis. Anis has a public key (e, n) where $n = p \times q$ in that p and q are large prime number. Show the message exchange process with related computation between Anis and Boshir using RSA Algorithm.**
   Use $M = 4, p = 3, q = 11, e = 3$
   Answer:



Here, $M = 4$
$p = 3$
$q = 11$
$n = p \times q = 3 \times 11 = 33$
$z = (p-1)(q-1) = 2 \times 10 = 20$
$e = 3$

Now,
At Boshir site,
Encrypting M into C,

$$\begin{aligned} C &= M^e \bmod n \\ &= 4^3 \bmod 33 \\ &= 31 \end{aligned}$$

At Anis site,
Calculating private key d,

$$\begin{aligned} d &= e^{-1} \bmod z \\ &= 3^{-1} \bmod 20 \\ &= \frac{1 + 20 \times k}{3} \bmod 20 \\ &= 7 \bmod 20 \\ &= 7 \end{aligned}$$

Decrypting C into M,

$$\begin{aligned} M &= C^d \bmod n \\ &= 31^7 \bmod 33 \\ &= (31^2 \bmod 33)^3 \times 31 \bmod 33 \\ &= 4^3 \bmod 33 \times 31 \bmod 33 \\ &= (64 \times 31) \bmod 33 \\ &= 4 \bmod 33 \\ &= 4 \end{aligned}$$

∴ Anis successfully decrypted the C into M.

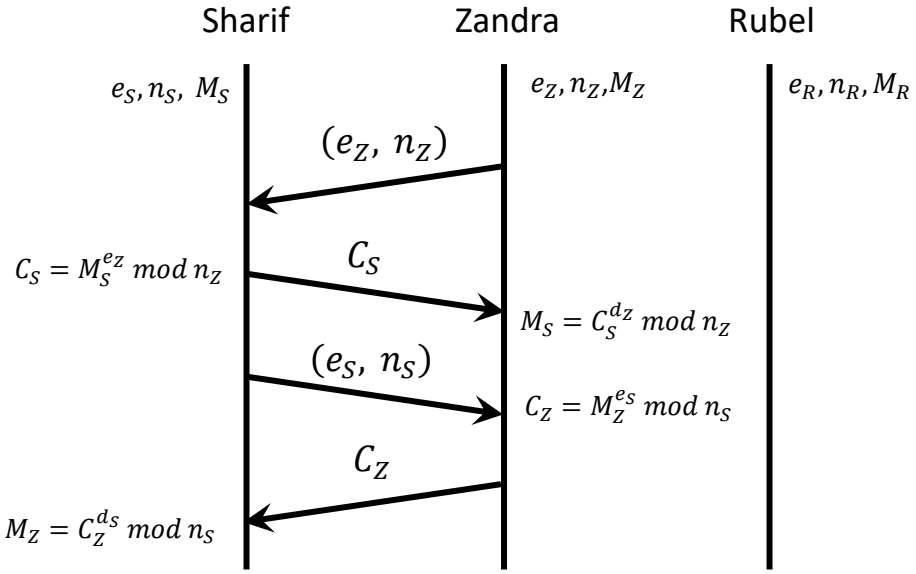
2. Suppose that, Sharif, Rubel, and an adversary Zandra use RSA algorithm for communication with following information.

	Sharif	**Rubel**	**Zandra**
Message: M	**11**	**8**	**3**
Prime numbers: (p, q)	**(3,11)**	**(7,11)**	**(5,7)**
Public key: e	**13**	**19**	**11**

Actually, Sharif wants to communicate to Rubel. However, Zandra takes over the communication channel. He sends Sharif his public key (e, n) impersonating Rubel. Sharif sends his message $M = 11$ to Zandra and Zandra replies back with $M = 3$. All messages that Rubel want sends to Sharif are discarded by Zandra. Now:

- **Calculate all the cipher and decipher messages**
- **Show the exchanges of messages between Sharif and Zandra**

Answer:



At first,
Sharif will encrypt his message M_S using Zandra's public key (e_z, n_Z).

$$
\begin{aligned}
C_S &= M_S^{ez} \; mod \; n_Z \\
&= 11^{11} \; mod \; 35 \\
&= (11^5 \; mod \; 35)^2 \times 11 \; mod \; 35 \\
&= 16^2 \; mod \; 35 \times 11 \; mod \; 35 \\
&= 11 \; mod \; 35 \times 11 \; mod \; 35 \\
&= (11 \times 11) \; mod \; 35 \\
&= 16
\end{aligned}
$$

Here,
$M_S = 11$
$e_Z = 11$
$n_Z = p_Z \times q_Z = 5 \times 7 = 35$

Now,
Zandra will decrypt C_S into M_S using his private key (d_z, n_Z).

$$
\begin{aligned}
d_Z &= e_Z^{-1} \; mod \; z_Z \\
&= 11^{-1} \; mod \; 24 \\
&= \frac{1 + 24 \times k}{11} \; mod \; 24 \\
&= 11 \; mod \; 24 \quad [For \; k = 5] \\
&= 11
\end{aligned}
$$

$$
\begin{aligned}
M_S &= C_S^{dz} \; mod \; n_Z \\
&= 16^{11} \; mod \; 35 \\
&= (16^2 \; mod \; 35)^5 \times 16 \; mod \; 35 \\
&= 11^5 \; mod \; 35 \times 16 \; mod \; 35 \\
&= (11^5 \times 16) \; mod \; 35 \\
&= 2576816 \; mod \; 35 \\
&= 11
\end{aligned}
$$

Here,
$z_Z = (p_Z - 1)(q_Z - 1) = 4 \times 6 = 24$
$e_Z = 11$

∴ Zandra successfully decrypted the C_S into M_S.

Now,
Zandra will encrypt his message M_Z using Sharif's public key (e_S, n_S).

$$
\begin{aligned}
C_Z &= M_Z^{eS} \; mod \; n_S \\
&= 3^{13} \; mod \; 33 \\
&= (3^2 \; mod \; 33)^6 \times 3 \; mod \; 33 \\
&= 9^6 \; mod \; 33 \times 3 \; mod \; 33 \\
&= 9 \; mod \; 33 \times 3 \; mod \; 33 \\
&= (9 \times 3) mod \; 33 \\
&= 27
\end{aligned}
$$

Here,
$M_Z = 3$
$e_S = 13$
$n_S = p_S \times q_S = 3 \times 11 = 33$

Now,
Sharif will decrypt C_Z into M_Z using his private key (d_S, n_S).

$$d_S = e_S^{-1} \, mod \, z_S$$
$$= 13^{-1} \, mod \, 20$$
$$= \frac{1 + 20 \times k}{13} \, mod \, 20$$
$$= 17 \, mod \, 20 \quad [For \, k = 11]$$
$$= 17$$

$$M_Z = C_Z^{d_S} \, mod \, n_S$$
$$= 27^{17} \, mod \, 33$$
$$= (27^2 \, mod \, 33)^8 \times 27 \, mod \, 33$$
$$= 3^8 \, mod \, 33 \times 27 \, mod \, 33$$
$$= 27 \, mod \, 33 \times 27 \, mod \, 33$$
$$= (27 \times 27) \, mod \, 33$$
$$= 3$$

Here,

$$z_S = (p_S - 1)(q_S - 1) = 2 \times 10 = 20$$
$$e_S = 13$$

∴ Sharif successfully decrypted the C_Z into M_Z.

Therefore, exchanges of all of the messages between Sharif and Zandra has been shown.

Diffie-Hellman Encryption / Decryption

1. **Anis and Boshir are communicating through Diffie-Hellman key exchange algorithm. They choose $p = 23$, and $g = 5$. Anis secret key $S_A = 6$ while Boshir choose $S_B = 15$. Anis sends the message $M_1 = 9$ and Boshir replies with $M_2 = 3$. Find the cipher texts and decipher texts between both sides. Show the message exchanges.**

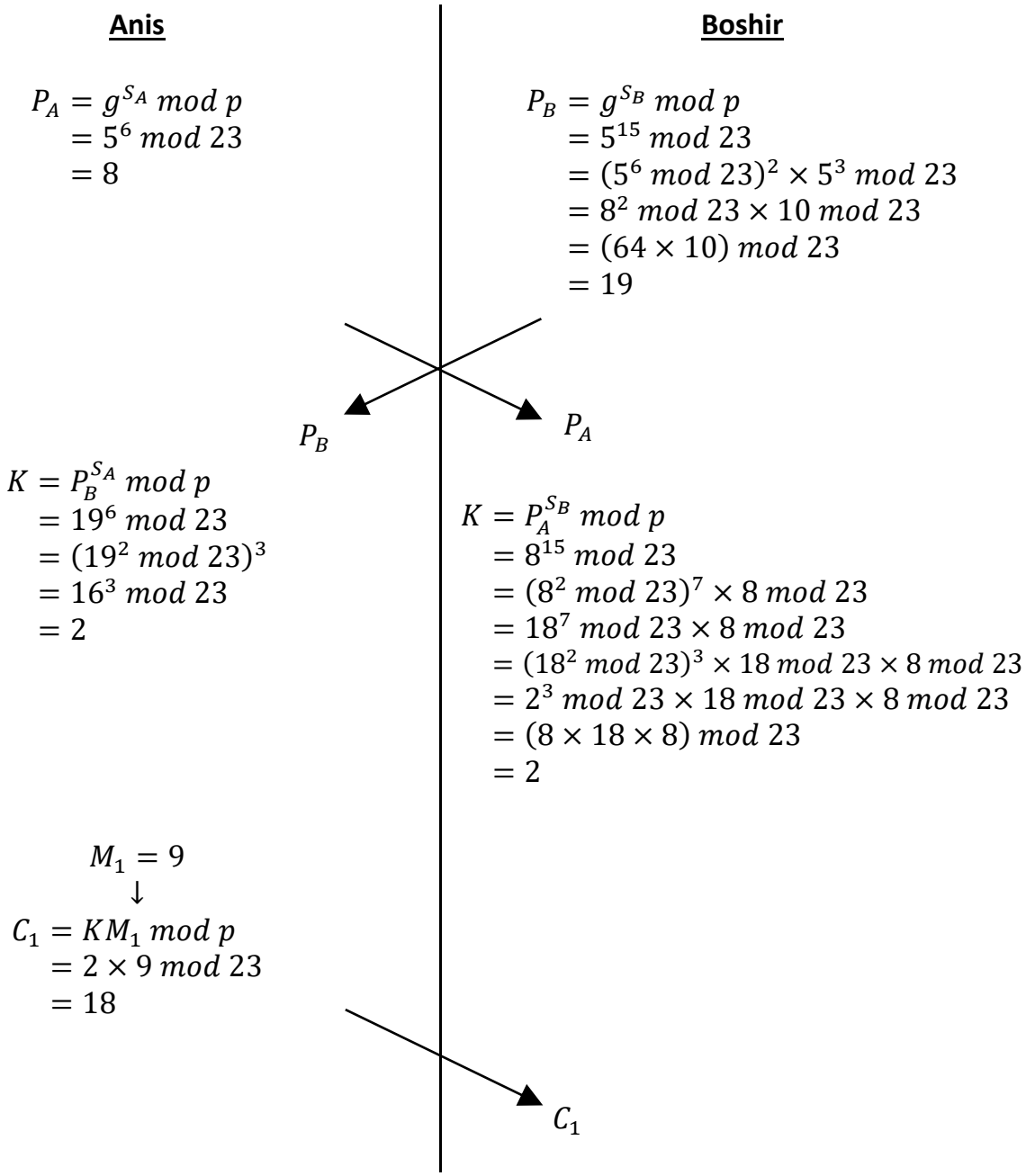
   Answer:

   Given,

   $p = 23 \qquad g = 5$

   $S_A = 6 \qquad S_B = 15$

   Now,



$$C_1 = 18$$
$$\downarrow$$
$$M_1 = K^{-1} C_1 \; mod \; p$$
$$= \frac{1}{2} \times 18 \; mod \; 23$$
$$= 9 \; mod \; 23$$
$$= 9$$

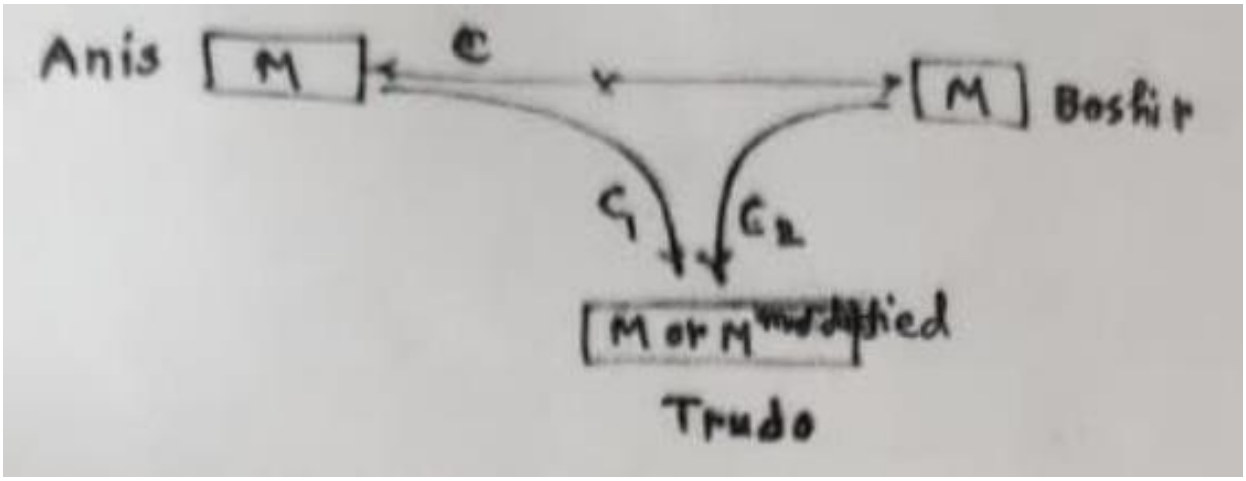
$$M_2 = 3$$
$$\downarrow$$
$$C_2 = K M_2 \; mod \; p$$
$$= 2 \times 3 \; mod \; 23$$
$$= 6$$

C_2

$$C_2 = 6$$
$$\downarrow$$
$$M_2 = K^{-1} C_2 \; mod \; p$$
$$= \frac{1}{2} \times 6 \; mod \; 23$$
$$= 3 \; mod \; 23$$
$$= 3$$

∴ Message exchanges between Anis and Bashir has been shown.

2. **Anis and Boshir want to communicate with each other using Diffie-Hellman key-exchange algorithm. However, Trudo establishes a MITM attack scenario:**



First, Anis wants to send the message $M_a$to Boshir. He encrypts $M_a$as C_a and sends. Trudo intercepts C_a and decrypts successfully as M_a. Trudo encrypts the message M_a as $C_{a,t}$ and sends to Boshir. Boshir decrypts $C_{a,t}$ as M_a. Boshir encrypts his reply message M_b as $C_b$and sends to Anis. Trudo intercepts the message and decrypts successfully as M_b. Now Trudo modifies the message as $M_t^{\{modified\}}$and encrypts as $C_t^{\{modified\}}$, which is then sent to Anis. Anis decrypts the message as $M_t^{\{modified\}}$, which is the modified message from Boshir.

Related parameters and values are given as follows:

Person	Secret Key	Message (M)	Ciphertext (C)	p, g
Anis	$s_a = 5$	$M_a = 9$	C_a	11, 2
Boshir	$s_b = 4$	$M_b = 10$	C_b	
Trudo	$s_t = 2$	$M_t^{\{modified\}} = 2$	$C_t^{\{modified\}}$	

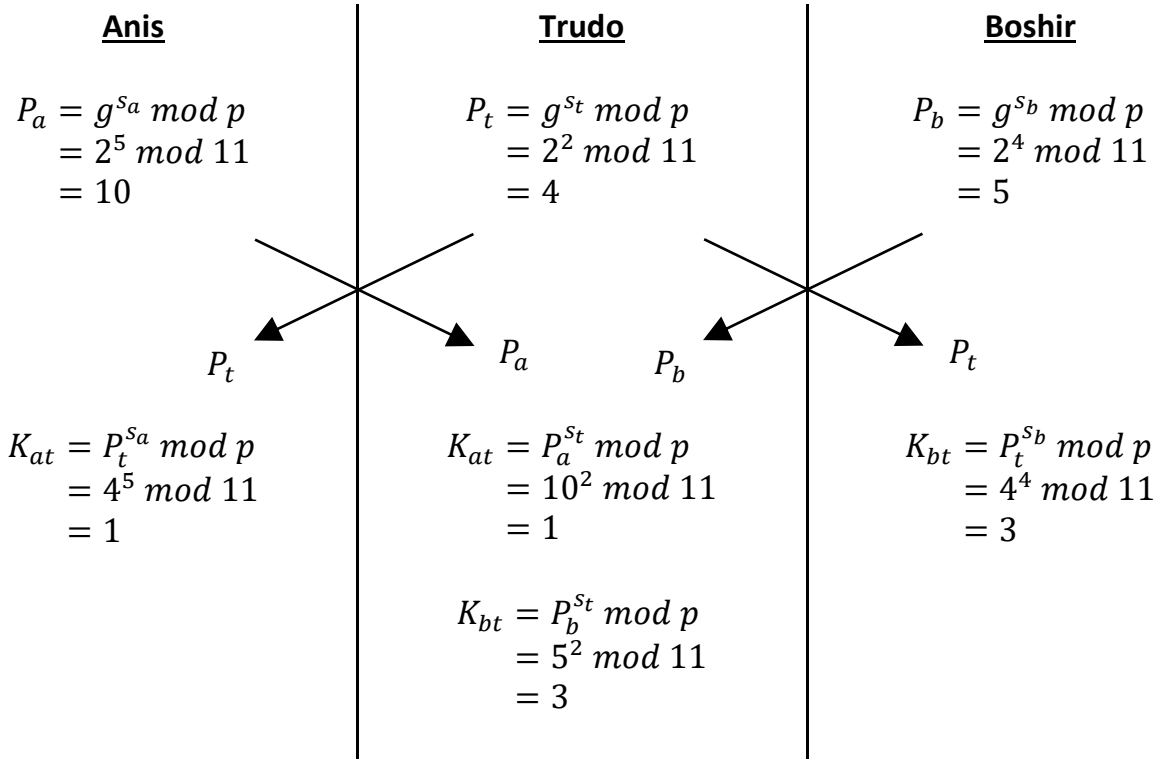
a) Compute the shared keys between Anis and Trudo; and Boshir and Trudo.
b) Calculate all the ciphertexts and deciphertexts related to the message exchanges.
c) Show the message exchanges among Anis, Trudo and Boshir.

Answer:

Given,

$p = 11 \qquad g = 2$
$s_a = 5 \qquad s_b = 4 \qquad s_t = 2$

Given,



Anis

$$M_a = 9$$
$$\downarrow$$
$$C_a = K_{at} M_a \ mod \ p$$
$$= 1 \times 9 \ mod \ 11$$
$$= 9$$

Trudo

$$C_a = 9$$
$$\downarrow$$
$$M_a = K_{at}^{-1} C_a \ mod \ p$$
$$= \frac{1}{1} \times 9 \ mod \ 11$$
$$= 9$$
$$\downarrow$$
$$C_{a,t} = K_{bt} M_a \ mod \ p$$
$$= 3 \times 9 \ mod \ 11$$
$$= 5$$

Boshir

$$C_{a,t} = 5$$
$$\downarrow$$
$$M_a = K_{bt}^{-1} C_{a,t} \ mod \ p$$
$$= \frac{1}{3} \times 5 \ mod \ 11$$
$$= \frac{1}{3} mod \ 11 \times 5 \ mod \ 11$$
$$= 4 \ mod \ 11 \times 5 \ mod \ 11$$
$$= (4 \times 5) \ mod \ 11$$
$$= 9$$

$$M_b = 10$$
$$\downarrow$$
$$C_b = K_{bt} M_b \ mod \ p$$
$$= 3 \times 10 \ mod \ 11$$
$$= 30 \ mod \ 11$$
$$= 8$$

$$C_b = 8$$

$$\downarrow$$

$$M_b = K_{bt}^{-1} C_a \; mod \; p$$

$$= \frac{1}{3} \times 8 \; mod \; 11$$

$$= \frac{1}{3} \; mod \; 11 \times 8 \; mod \; 11$$

$$= 4 \; mod \; 11 \times 8 \; mod \; 11$$

$$= (4 \times 8) \; mod \; 11$$

$$= 10$$

$$\downarrow$$

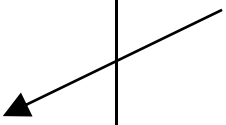
$$M_t^{\{\text{modified}\}} = 2$$

$$\downarrow$$

$$C_t^{\{\text{modified}\}} = K_{at} M_t^{\{\text{modified}\}} \; mod \; p$$

$$= 1 \times 2 \; mod \; 11$$

$$= 2$$



$$C_t^{\{\text{modified}\}} = 2$$

$$\downarrow$$

$$M_t^{\{\text{modified}\}} = K_{at}^{-1} C_t^{\{\text{modified}\}} \; mod \; p$$

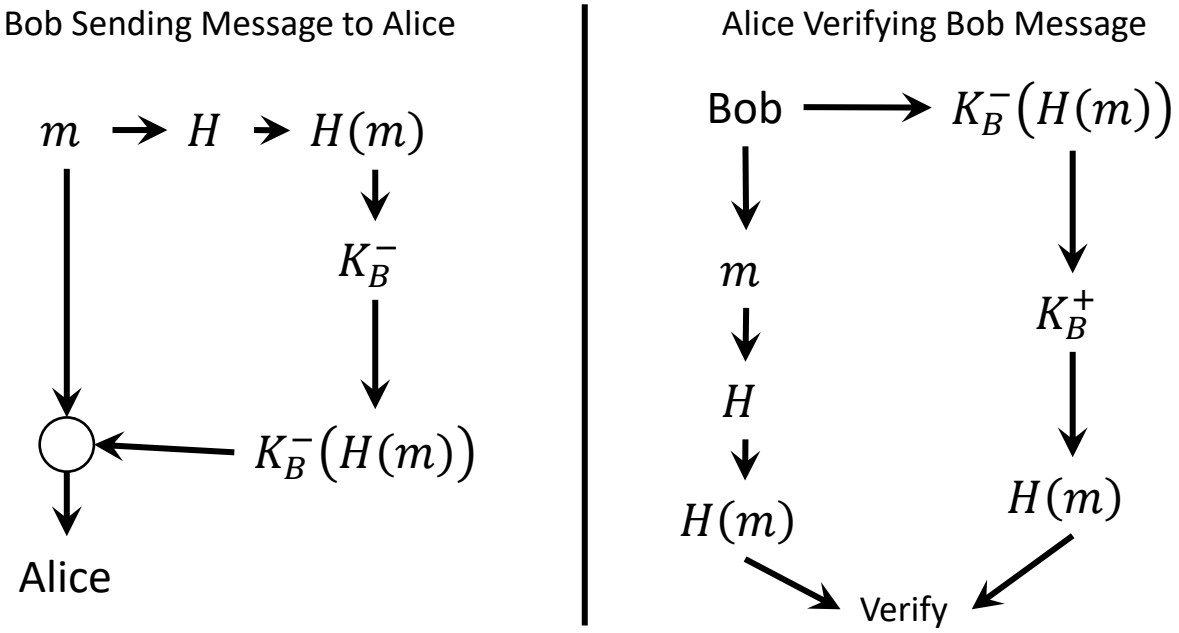
$$= \frac{1}{1} \times 2 \; mod \; 11$$

$$= 2 \; mod \; 11$$

$$= 2$$

Digital Signature

1. **What is Digital Signature?**
   Answer: A digital signature is a cryptographic technique similar to a handwritten signature. It provides authentication, integrity, and non-repudiation.



2. **Anis sends a message $M = 20$ to his friend Boshir with a digital signature using RSA algorithm. He considers $p = 17, q = 11, d = 7, n = p \times q$ with a hash functions $h(x) = Ax + C \ mod \ n$, where $A = 4, C = 8$.**
   Show step by step process how Anis generates the digital signature and Boshir verifies the authenticity of message.
   Answer:
   Here,

$p = 17 \qquad q = 11$
$d = 7 \qquad n = p \times 1 = 11 \times 17 = 187$
$h(x) = Ax + C \ mod \ n$
$A = 4 \qquad C = 8$
$z = (p-1)(q-1) = 16 \times 10 = 160$

At first, Anis will make hash of the message and encrypt with his private key.
Calculating hash value:

$$h(M) = Ax + C \ mod \ n$$
$$h(20) = 4 \times 20 + 8 \ mod \ 187$$
$$= 88 \ mod \ 187$$
$$= 88$$

Encrypt hash value with RSA:

$$\begin{aligned} S &= h^d \ mod \ n \\ &= 88^7 \ mod \ 187 \\ &= (88^2 \ mod \ 187)^3 \times 88 \ mod \ 187 \\ &= 77^3 \ mod \ 187 \times 88 \ mod \ 187 \\ &= 66 \ mod \ 187 \times 88 \ mod \ 187 \\ &= (66 \times 88) \ mod \ 187 \\ &= 11 \end{aligned}$$

Now,
Anis will calculate hash value and decrypt encrypted digital signature and compare them.
Calculating hash value in Anis site:

$$\begin{aligned} h &= 4 \times 20 + 8 \ mod \ 187 \\ &= 88 \ mod \ 187 \\ &= 88 \end{aligned}$$

Here,

$$\begin{aligned} e &= d^{-1} \ mod \ z \\ &= \frac{1}{7} \ mod \ 160 \\ &= \frac{1 + 160 \times k}{7} \ mod \ 160 \\ &= 23 \ mod \ 160 \\ &= 23 \end{aligned}$$

Decrypting S using Anis public key:

$$\begin{aligned} h' &= S^e \ mod \ n \\ &= 11^{23} \ mod \ 187 \\ &= (11^5 \ mod \ 187)^4 \times 11^3 \ mod \ 187 \\ &= 44^4 \ mod \ 187 \times 22 \ mod \ 187 \\ &= (44^2 \ mod \ 187)^2 \times 22 \ mod \ 187 \\ &= 66^2 \ mod \ 187 \times 22 \ mod \ 187 \\ &= 55 \ mod \ 187 \times 22 \ mod \ 187 \\ &= (55 \times 22) \ mod \ 187 \\ &= 88 \end{aligned}$$

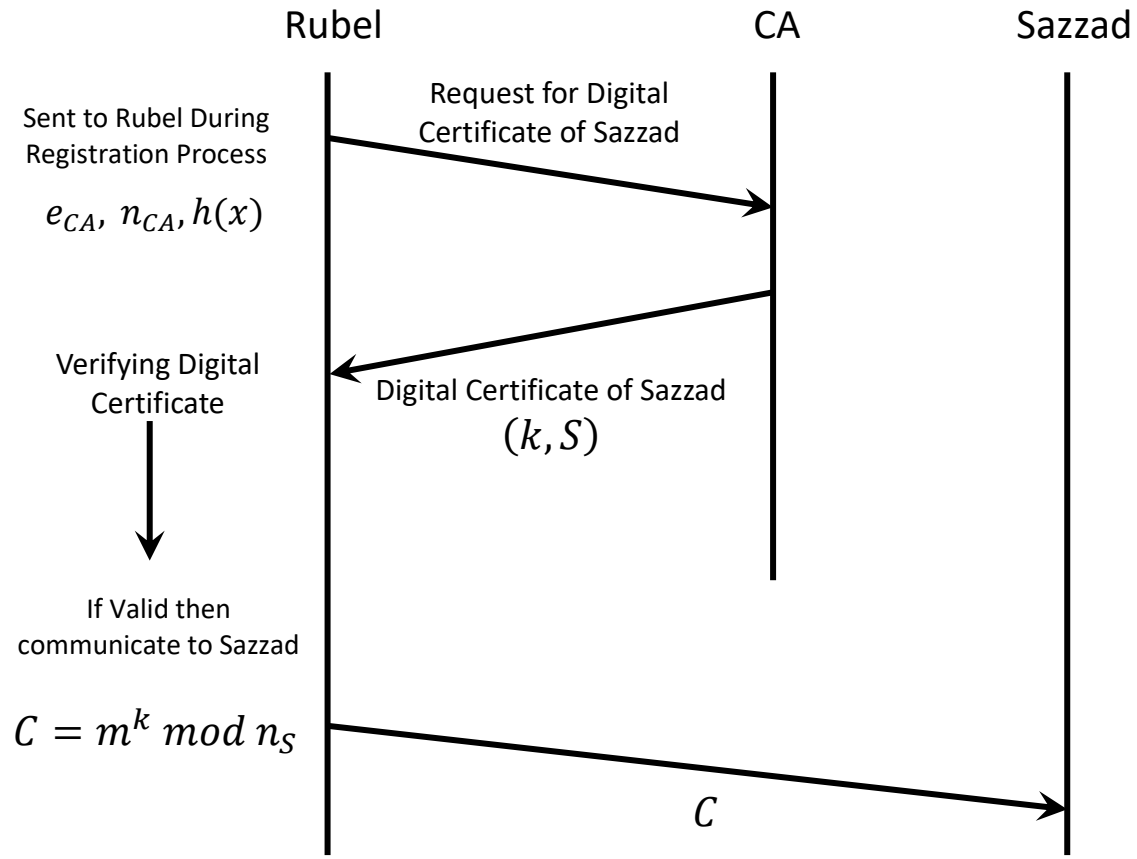
Since $h = h'$, therefore verified.

Digital Certificate

1. **Rubel receives a public key $k = 11$ along with a digital ceritifacte S from CA. This k belongs to Sazzad to whom Rubel wants to communicate. CA uses RSA digital certificate algorithm with the following parameters:**

   Prime numbers: $p = 3, q = 11$
   Private key: $d = 3$
   Hash functions: $h(z) = Az + b \ mod \ R$
   Where $A = 9$, $b = 7$, $R = 13$

   Calculate the digital certificate S for k and process to verify digital certificate from Rubel.
   Answer:



Given,

$p_{CA} = 3 \qquad q_{CA} = 11 \qquad k = 11$
$d_{CA} = 3 \qquad n_{CA} = p_{CA} \times q_{CA} = 33$
$h(z) = Az + b \ mod \ R$
$A = 9 \qquad b = 7 \qquad R = 13$
$z_{CA} = (p-1)(q-1) = 2 \times 10 = 20$

At first in At the site of CA,

Calculating the hash value of Sazzad public key k,

$$\begin{aligned} h(k) &= Ak + b \; mod \; R \\ &= 9 \times 11 + 7 \; mod \; 13 \\ &= 106 \; mod \; 13 \\ &= 2 \end{aligned}$$

Now encrypting hash value with CA private key,

$$\begin{aligned} S &= h^{d_{CA}} \; mod \; n_{CA} \\ &= 2^3 \; mod \; 33 \\ &= 8 \; mod \; 33 \\ &= 8 \end{aligned}$$

Verifying at the site of Rubel,

Calculating the hash value of Sazzad public key k,

$$\begin{aligned} h &= Ak + b \; mod \; R \\ &= 9 \times 11 + 7 \; mod \; 13 \\ &= 106 \; mod \; 13 \\ &= 2 \end{aligned}$$

Now decrypting S with CA public key,
Here,

$$\begin{aligned} e_{CA} &= d_{CA}^{-1} \; mod \; z_{CA} \\ &= \frac{1}{3} \; mod \; 20 \\ &= 7 \end{aligned}$$

Now,

$$\begin{aligned} h &= S^{e_{CA}} \; mod \; n_{CA} \\ &= 8^7 \; mod \; 33 \\ &= (8^3 \; mod \; 33)^2 \times 8 \bmod 33 \\ &= 25 \; mod \; 33 \times 8 \bmod 33 \\ &= (25 \times 8) \bmod 33 \\ &= 2 \end{aligned}$$

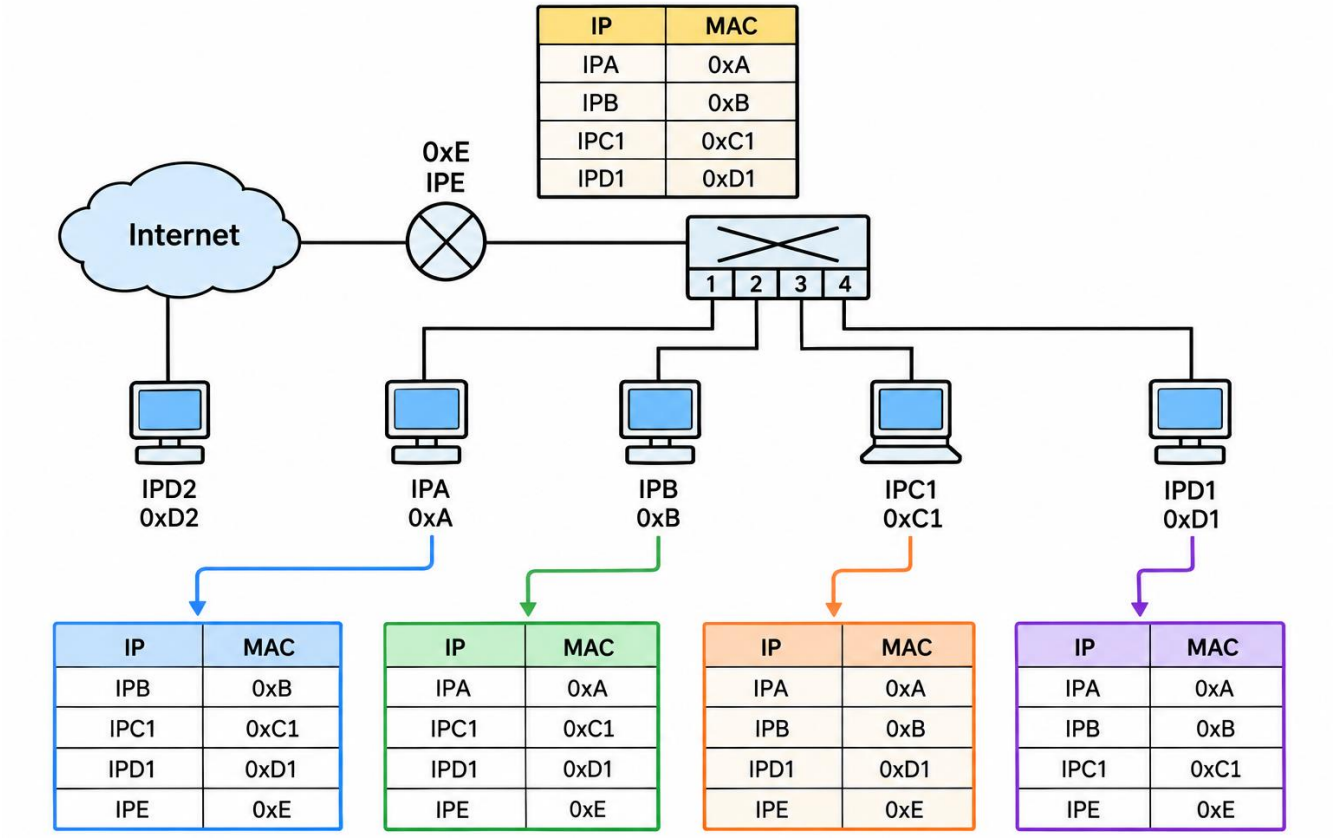
Since $h = h'$, therefore verified.

MITM and ARP Spoofing

1. **What is ARP?**

   Answer: ARP (Address Resolution Protocol) is a network protocol that works by broadcasting requests to find the MAC address associated with a specific IP address and caching the responses for future use.

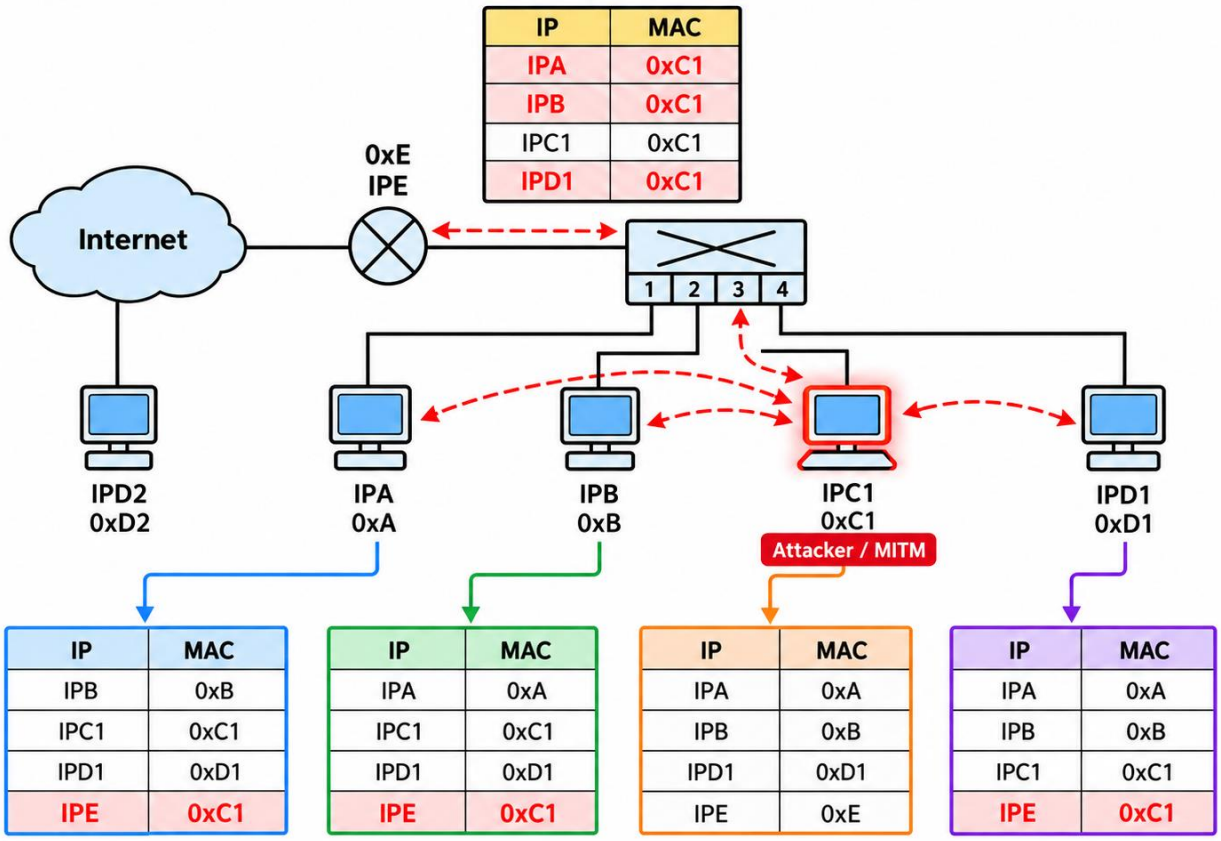
   When a computer needs a MAC address, it broadcasts a request: “Who has IP address1? Tell IP address2.” The machine with that IP address responds with its MAC address: “IP address1 is at MAC address.” The response is then stored in the ARP table for future use.



2. **What is ARP Spoofing?**

   Answer: ARP Spoofing is a network attack in which a rogue machine sends fake ARP replies to poison the ARP cache of other machines by providing false IP-to-MAC address mappings.

   ARP is a stateless protocol, meaning ARP requests are not tracked, and the ARP table is updated whenever an ARP reply is received, even if no request was sent. Since ARP announcements are not authenticated and machines trust each other, an attacker can send gratuitous ARP replies to update the victim's ARP cache with false information and spoof other machines on the network.



3. **How ARP Spoofing can be defended?**

   Answer:

   - **Static ARP Entries:** Using static ARP entries can prevent ARP spoofing, but they are very difficult to manage.
   - **Check Duplicate MAC Addresses:** Detect multiple occurrences of the same MAC address mapped to different IP addresses, which may indicate ARP spoofing.
   - **Dynamic ARP Inspection (DAI):** Use Dynamic ARP Inspection on network switches to detect and prevent ARP spoofing. However, it may slow down switching performance.
   - **Software Detection Solutions:** Use tools such as Anti-arpspoof, Xarp, and Arpwatch to detect ARP spoofing attacks.

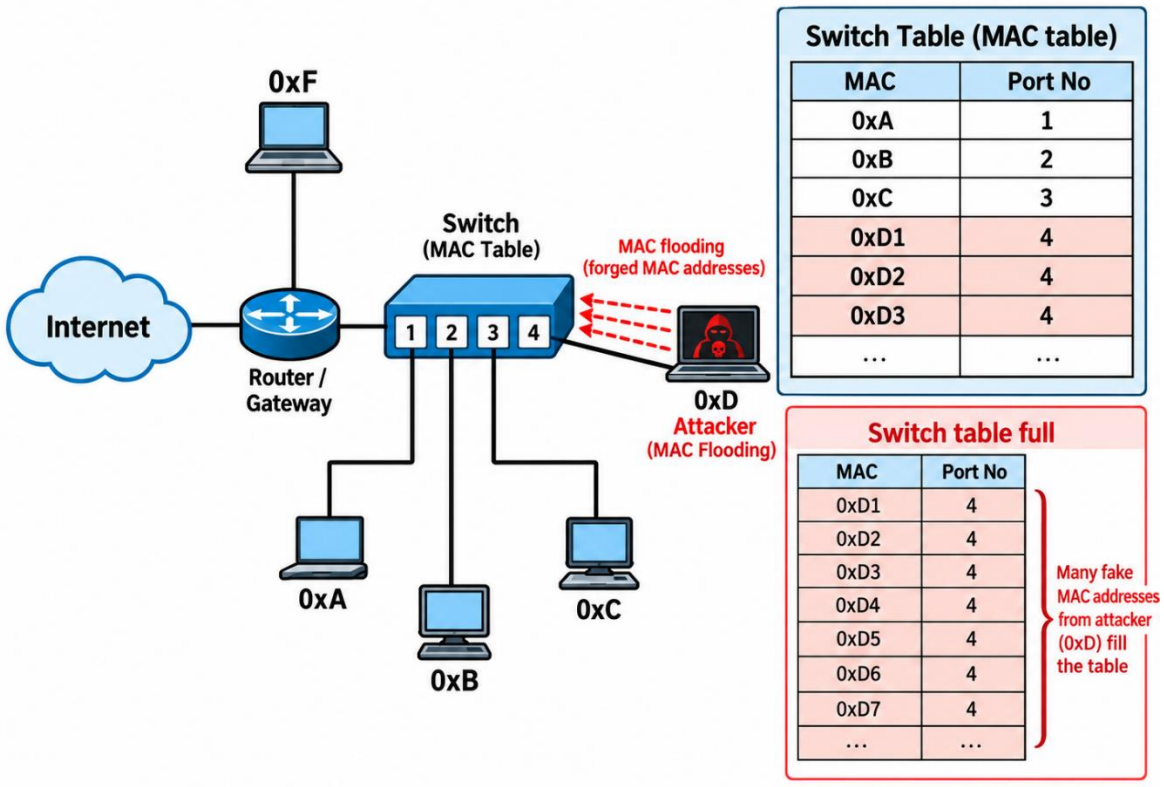
Switch / MAC Table Flooding

1. **What is MAC Address Table Flooding?**

   Answer: MAC Address Table Flooding is a network attack that takes advantage of the fixed size of a switch's MAC address table. Since the table has limited capacity, an attacker floods the switch with fake source MAC addresses until the MAC address table becomes full.

   When the table is full, the switch cannot learn new MAC addresses and treats frames with unknown destination MAC addresses as unknown unicasts. As a result, the switch starts broadcasting (flooding) incoming traffic to all ports except the incoming port, without referencing the MAC table.

   This allows the attacker to capture frames sent between hosts on the local LAN or VLAN, compromising network security.



2. **How to prevent MAC Table Flooding attack?**

   Answer:

   - Enable port security
   - Limit MAC address number per switch port
   - Disable unused switch port
   - Detect which port consuming more energy

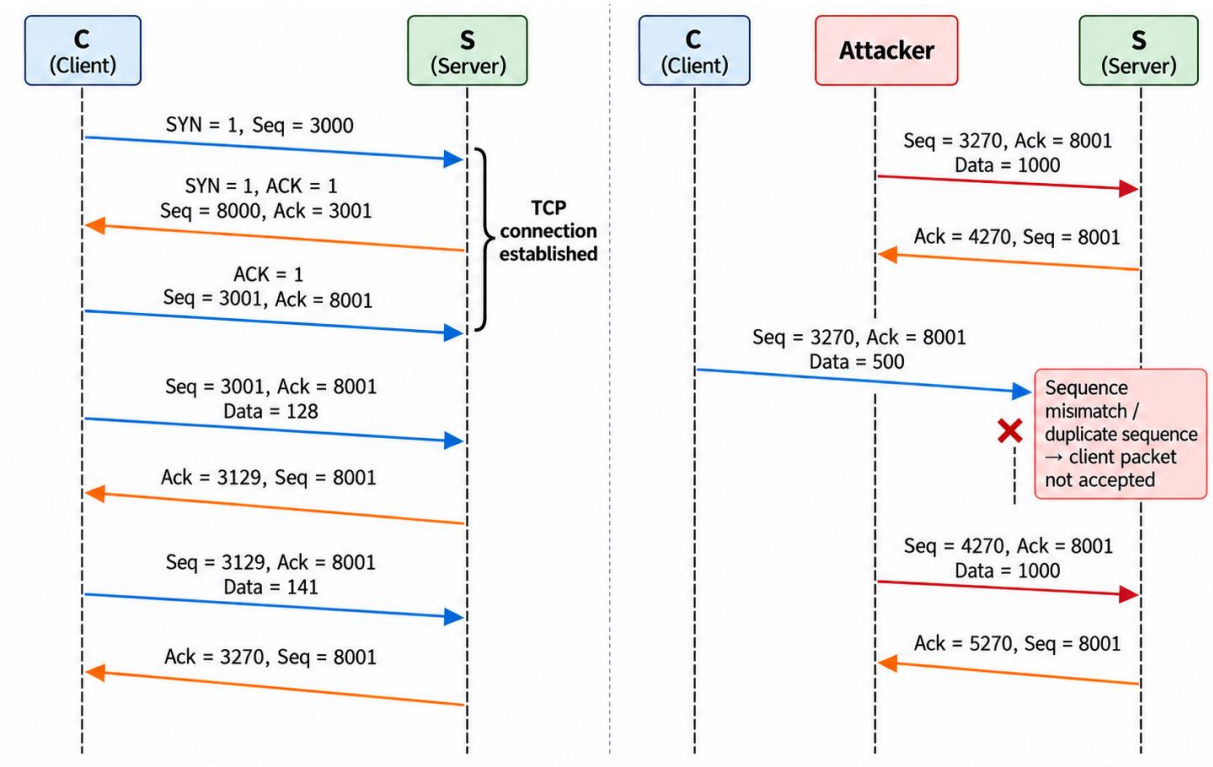
TCP Session Hijacking

1. **What is TCP Session Hijacking? How its work?**

   Answer: TCP Session Hijacking is an attack in which an attacker takes control of an established TCP connection by using correct sequence (seq) and acknowledgment (ack) numbers along with a spoofed IP address.

   Each TCP packet contains seq and ack numbers, which are negotiated between the client and server during the TCP connection setup stage (three-way handshake). These numbers have a size of 32 bits (2^{32} possible values), making them difficult to guess and an established TCP connection hard to hijack.

   An attacker on the same network segment as the target machine can sniff TCP packets and obtain the correct seq/ack numbers. The attacker can then inject packets using these numbers and a spoofed IP address. IP spoofing requires low-level packet programming rather than normal OS-based socket programming.



2. **How to prevent TCP Session Hijacking?**

   Answer

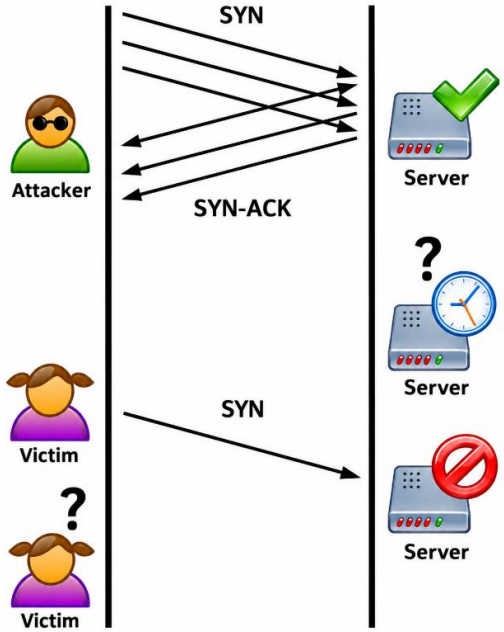
   - Use SSH, TLS or HTTPS to protect communication from sniffing and data theft.
   - Use secure session cookies

SYN Flooding Attack

4. **What is SYN Flooding Attack? How its work?**

   Answer: A SYN Flooding Attack is a type of Denial-of-Service (DoS) attack in which an attacker sends a large number of SYN requests to a target system, but does not sent last ACK response. Server wait for acknowledgement but attacker than don't responded to it, which make server more not responding. The target uses excessive memory and CPU resources to process these fake connection requests, and its network bandwidth becomes overloaded.

   Usually, SYN flood packets use spoofed source IP addresses to hide the attacker's identity. As a result, no complete TCP connection is established, unlike TCP Session Hijacking. The use of spoofed IP addresses also makes it difficult for the target system to distinguish between malicious SYN requests and legitimate user requests, disrupting normal network services.



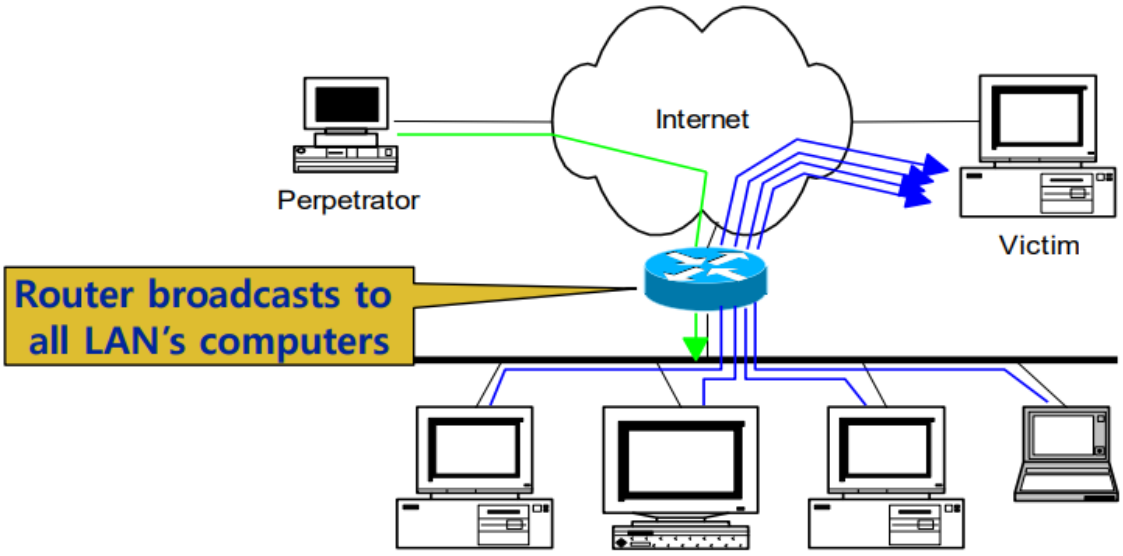
5. **How SYN Flooding Attack can be prevent? What is SYN Cookie?**

   Answer: SYN Flooding Attack প্রতিরোধ করার জন্য SYN Cookie ব্যবহার করা হয়। SYN Flooding Attack-এ attacker সার্ভারে অনেক SYN request পাঠায়, কিন্তু TCP three-way handshake সম্পন্ন করে না। ফলে অনেক connection half-open অবস্থায় থাকে এবং server-এর resources নষ্ট হয়।
   SYN Cookie হলো এমন একটি পদ্ধতি, যেখানে server শুরুতে কোনো memory allocate বা connection state save না করেই একটি বিশেষ sequence number (SYN Cookie) সহ SYN-ACK packet পাঠায়। এরপর client সঠিক ACK পাঠালে server সেই SYN Cookie যাচাই করে। Server একটি secret key, source ও destination IP address, port numbers এবং time-related value ব্যবহার করে HMAC দিয়ে একটি বিশেষ TCP sequence number (SYN Cookie) তৈরি করে। যদি সেটি valid হয়, তাহলে server memory allocate করে TCP connection establish করে। এভাবে SYN Cookie সার্ভারকে SYN Flooding Attack থেকে রক্ষা করতে সাহায্য করে।

Smurf Attack

1. **What is Smurf Attack?**

   Answer: A Smurf Attack is a type of Denial-of-Service (DoS) attack that uses ICMP (Internet Control Message Protocol) echo request and reply packets with broadcast networks to multiply network traffic and overload the system of a victim.



   In this attack, the attacker sends ICMP echo request packets to a network's broadcast IP address using the victim's spoofed IP address as the source. The router broadcasts these requests to all computers on the LAN. Each computer then sends an ICMP echo reply to the victim, generating a large amount of traffic.

   The attacker abuses these broadcast networks as “bounce-sites” to amplify traffic, potentially overloading the victim's system and making it unavailable to legitimate users.

2. **How to Prevent Smurf Attack?**

   Answer:

   - **Disable Directed Broadcasts:** Turn off directed broadcasts to subnets with five or more hosts. In Cisco routers, use the command “no ip directed-broadcast”.
   - **Use Access Control Lists (ACLs):** Prevent ICMP echo requests from entering the network. However, this method can make network troubleshooting difficult.
   - **Disable ICMP Echo Replies:** Prevent devices from replying to ICMP echo requests sent to broadcast addresses. According to RFC-1122, ICMP echo requests sent to IP broadcast or multicast addresses may be silently discarded.

Malware

1. **What is Virus? Give an example.**
   Answer: A computer virus is a malicious program that propagates by infecting other programs and automatically creating copies of itself. Example:
   - **Macro Virus:** A macro is an executable program embedded in a word processing document (MS Word) or spreadsheet (Excel). When infected document is opened, virus copies itself into global macro file and makes itself auto-executing.

2. **Write the phases of Virus.**
   Answer:
   - **Dormant phase.** During this phase, the virus just exists, the virus is laying low and avoiding detection.
   - **Triggering phase.** In this phase, some logical condition causes the virus to move from a dormant or propagation phase to perform its intended action.
   - **Propagation phase.** During this phase, the virus is replicating itself, infecting new files on new systems.
   - **Action phase.** In this phase, the virus performs the maliciousaction that it was designed to perform, called **payload**.

3. **Discuss virus propagation methods.**
   Answer: A virus propagates by infecting other programs and automatically creating copies of itself. However, a human must run an infected program for the virus to spread.

   Viruses can propagate through various methods, such as:
   - **Executable File Infection:** A virus inserts a copy of itself into executable files such as .COM and .EXE.
   - **Boot Sector Infection:** A virus inserts a copy of itself into the boot sectors of disks. For example, the Stoned virus infected PCs booted from infected floppy disks, stayed in memory, and infected other inserted floppy disks.
   - **TSR Routine Infection:** A virus infects Terminate and Stay Resident (TSR) routines or common OS routines, allowing it to remain in memory and infect other disks and executable files.

   Example:
   - **Viruses in P2P Networks:** In P2P networks, millions of users download and share files, so viruses can spread easily. Attackers hide viruses in files that look like popular software, such as Photoshop or WinZip. Infected MP3 files are rare. When users open infected files, malware can create backdoors, steal private information, and send spam messages. Many infected computers are also listed on spam blacklists.
   - **Propagation via Websites, Drive-By Downloads**

4. **What is Concealment?**

   Answer: Concealment is a technique used by viruses to hide their malicious code and avoid detection by antivirus software. There are three main types:

   - **Encrypted Virus:** An encrypted virus consists of a decryption engine and an encrypted virus body. It randomly generates encryption keys and may use brute-force decryption. Antivirus software detects it by identifying the decryption engine.

Decryption Engine	Encrypted Body

   - **Polymorphic Virus:** A polymorphic virus is an encrypted virus that creates random variations of its decryption engine. These variations make signature-based detection difficult. It can be detected using a CPU emulator.

Different Decryption Engine	Different Encrypted Body

   - **Metamorphic Virus:** A metamorphic virus creates different versions of its virus body while maintaining the same functionality. It uses techniques such as code permutation and instruction replacement. It is challenging to detect because its code structure changes.

Different Virus Code	Same Functionality

5. **Describe Anti-Virus Technologies.**

   Answer:

   - **Simple Anti-Virus Scanners** Simple anti-virus scan ners use the following methods to detect viruses:
     - **Signature-Based Detection:** A signature is a unique fingerprint of a virus, usually a sequence of instructions specific to that virus. It is different from a digital signature. Antivirus software compares scanned files with a database of known malware signatures using fast pattern-matching techniques.
     - **Heuristic Analysis:** It is an antivirus technique used to detect new and zero-day malware by examining suspicious code and program behavior. It uses two main methods:
       - **Code Analysis:** Examines program instructions to identify malicious activities, such as instructions to delete system files.
       - **Execution Emulation:** Runs the program in an isolated environment, such as a virtual machine, and monitors its actions. If harmful behavior is detected, the program is marked as malicious.
     - **Integrity Checking:** Detects modified files by comparing their file sizes, checksums, and Message Authentication Codes (MACs). This method is also used for rootkit detection.

   - **Generic Decryption and Emulation:** This technique emulates CPU execution for a few hundred instructions, allowing an encrypted virus to decrypt itself. Once decrypted, the antivirus can recognize the known virus body and detect the infection. However, this technique is less effective against mutating viruses and viruses whose code is not located near the beginning of an infected executable file.

6. **What is Worm?**

Answer: A worm is a standalone malicious program that propagates automatically by copying itself to other target systems without requiring human assistance. Unlike a virus, a worm does not need to infect a host program to spread. Example:

- **Morris Worm:** The Morris Worm appeared in 1988. It had no malicious payload, but it slowed down infected machines through uncontrolled spawning (repeatedly creating copies of itself). It infected approximately 10% of all Internet hosts at that time.

7. **How Worm propagate?**

Answer: A worm propagates automatically by finding vulnerable systems, infecting them, and creating copies of itself without requiring human assistance.

The worm propagation process involves three main steps:

- **Find New Targets:** The worm searches for new target systems, often using random IP address scanning to identify vulnerable hosts**.**
- **Compromise Targets:** After finding a target, the worm infects it by exploiting system vulnerabilities or tricking users into running malicious code through spam messages.
- **Spread Infection:** Once a system is infected, it becomes part of the infection army and starts searching for and infecting other systems. This process repeats and worm to spread rapidly.

8. **Write Propagation Theory of Worm.**

Answer: The Classic Epidemic Model explains how worms spread across victim hosts over time.

Here,

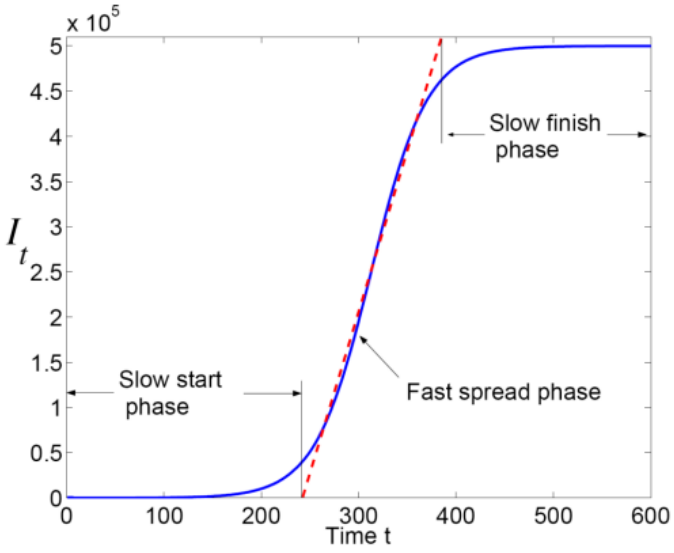
N: Total number of vulnerable hosts
$I(t)$: No of infected hosts at time t
$S(t)$: No of not infected hosts at time t
β: Infection rate

The total number of vulnerable hosts is:

$$I(t) + S(t) = N$$

The rate of worm propagation is represented by the differential equation:

$$\frac{dI}{dt} = \beta I(t) S(t)$$



9. **What is rootkit? How its work?**

Answer: A rootkit is a stealth technology used to hide malware and make it difficult to detect or remove. It applies cloaking techniques to conceal malicious activities from users and security software. A rootkit is not necessarily malware by itself, but it is often used by malware to remain hidden in a system.

Working Process:

A rootkit works by modifying or manipulating operating system functions to hide the presence of malware. Through cloaking techniques, modern rootkits can hide processes, services, TCP/IP ports, files, registry keys, and user accounts. Rootkits use several major techniques:

- User-Mode API Filtering
- Kernel-Mode API Filtering
- Kernel-Mode Data Structure Manipulation
- Process Hijacking

10. How to detect rootkits? How we can remove it?

Answer: Rootkits use cloaking techniques to hide their presence, but all cloaking techniques have weaknesses that can be used for detection:

- **Unfiltered APIs:** Rootkits may leave some APIs unfiltered, allowing security tools to detect hidden activities.
- **Detectable Side Effects:** Rootkits may produce side effects that reveal their presence.
- **Detection Tools:** Rootkit detection is a continuous cat-and-mouse game between attackers and security researchers.

Some known rootkit detection tools are: Microsoft Research Strider, RKDetect, Sysinternals RootkitRevealer etc.

The recommended method for removing a rootkit is to reformat the system and reinstall Windows, unless specific uninstall instructions are available from an authoritative source.

Users should not rely only on the rename functionality offered by some rootkit detectors because the detector may not identify all components of the rootkit and renaming detected components may not effectively remove the rootkit.

11. What is Trojan Horses?

Answer: A Trojan horse is a malware program that appears to perform some useful task, but which also does something with negative consequences (e.g., launches a keylogger). Trojan horses can be installed as part of the payload of other malware but are often installed by a user or administrator, either deliberately or accidentally.

12. What is Quarantine?

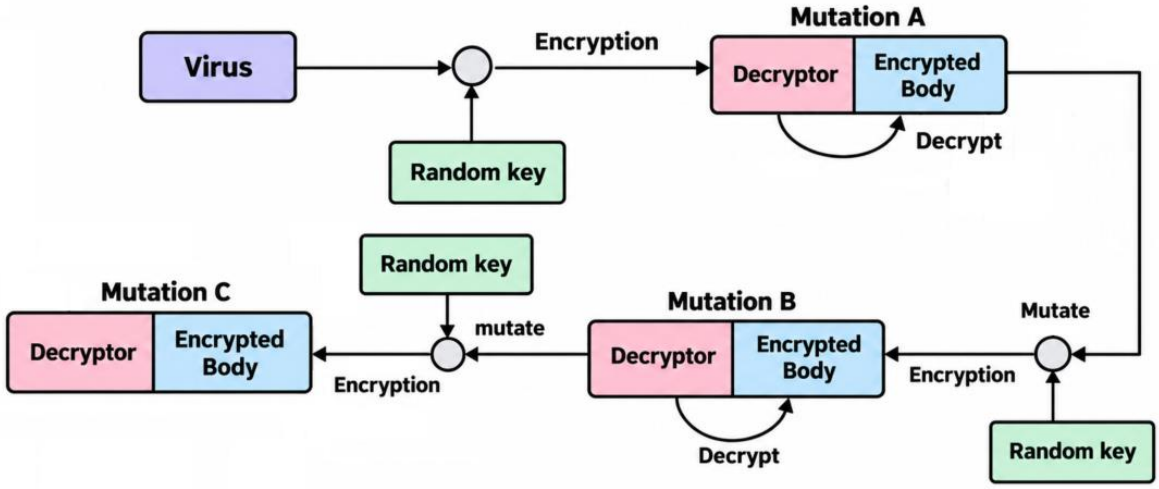
Answer: Quarantine is an antivirus technique that isolates suspicious files in a secure folder to prevent them from causing harm. The file is not deleted but made harmless through encryption, and it can only be accessed through the antivirus program. Users can later delete the file or restore it if it is identified as a false positive.

Quarantine is especially useful when heuristic analysis detects suspicious files while waiting for a malware signature database update.

13. What is Mutation / Obfuscation Techniques?

Answer: Mutation is a technique used by viruses to modify their code while maintaining the same functionality, making signature-based detection difficult. Virus mutation is a stealth technique in which a virus has multiple binary variants to avoid detection.

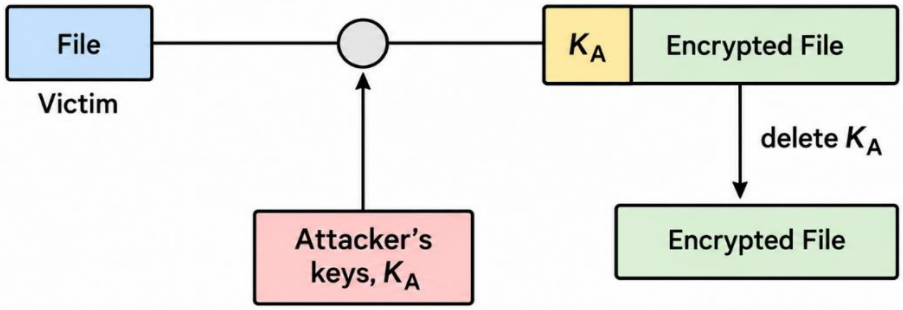
Mutation techniques include changing register names while keeping the same code (Regswap), rearranging subroutine order (BadBoy, Ghost), and decrypting the virus body instruction by instruction to rebuild it on the stack (Zmorph).



These made hard to recognize virus body, making signature-based detection difficult.

14. What is Ransomware?

Answer: Ransomware is a type of malware that encrypts files or locks a computer system and demands ransom payment to restore access.



Ransomware enters a system through malicious emails, infected downloads, or software vulnerabilities. Once installed, it encrypts important files or locks the system and demands payment to restore access to the data.

15. What is Zero-Day attack?

Answer: A Zero-Day Attack is a cyberattack that exploits a previously unknown or unpatched vulnerability in software, hardware, or a computer system. It occurs when attackers discover and exploit a security weakness before the software developer can release a security patch or fix.

The term “Zero-Day” means that developers have had zero days to fix the vulnerability before it is exploited. Attackers can use these vulnerabilities to gain unauthorized access, steal sensitive information, install malware, or damage computer systems.

16. What is DDoS?

Answer: A Distributed Denial-of-Service (DDoS) attack involves sending attack packets from multiple computers simultaneously to make a targeted server unavailable. Botnets are commonly used to launch DDoS attacks because they allow attackers to control multiple compromised computers and generate large amounts of traffic.

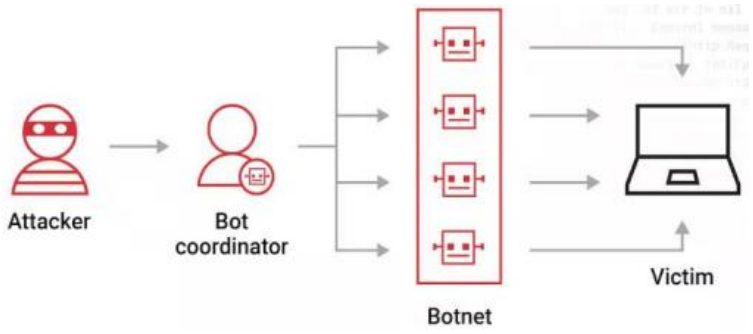
DDoS attacks can target a server in three ways:

- **Network Bandwidth:** Overloading the network bandwidth of the targeted server with excessive traffic.
- **Computing Resources:** Exhausting the targeted server's resources, such as CPU and memory.
- **Server Vulnerabilities:** Exploiting vulnerabilities, such as buffer overflow or logic bugs, to crash the server's operating system or programs (e.g., Apache, Sendmail, SQL).

17. Write the formats of DDoS attack.

Answer: There are three common formats of Denial-of-Service (DoS) attacks:

- **Real IP-based Attack Using Botnets:** Attackers use botnets to flood the targeted server with traffic without worrying about exposing the bots' IP addresses. Examples include TCP flooding, UDP flooding, and ICMP flooding.
- **Spoofed IP-based Attack:** Attackers use fake source IP addresses to hide the actual source of attack traffic. An example is SYN flooding with spoofed IPs.
- **Source Address Hiding Attack:** Attackers hide the original source address by using techniques such as Smurf attacks, where spoofed ICMP requests cause multiple devices to send replies to the victim.



18. What are Botnets?

Answer: A botnet is a collection of compromised hosts that spread like worms and viruses. Once installed, they respond to remote commands. A botnet is a network of bots, where a bot (robot) is an automatic machine that can be programmed to perform specific tasks. These compromised hosts are also known as zombies. Botnets provide a platform for many attacks, including spam forwarding, click fraud, keystroke logging, and Distributed Denial of Service (DDoS) attacks. Botnets are a serious security problem and a top concern for banks and online merchants.

19. **How to monitor botnet? What is Honeypot Spy?**

Answer: Security researchers set up honeypots, which are deliberately vulnerable machines designed to attract malware attacks. When a compromised honeypot joins a botnet, researchers use two monitoring techniques:

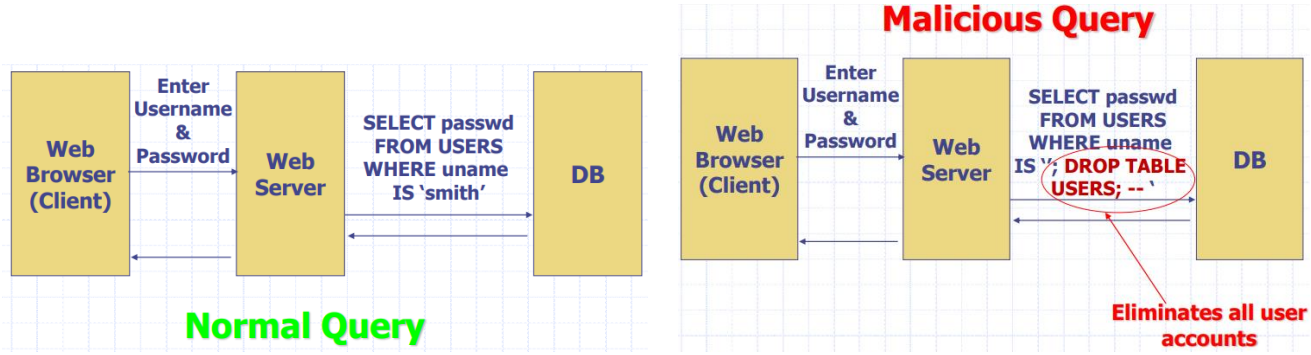
- **Passive Monitoring:** Logs all network traffic to observe communication and malware activities.
- **Active Monitoring:** Actively contacts other bots to obtain more information, such as neighborhood lists and additional C&C servers.

Web Attacks

1. **What is SQL Injection?**

   Answer: SQL injection is the placement of malicious code in SQL statements, via web page input. SQL Injection is an input validation vulnerability that occurs when untrusted user input is inserted into an SQL query without proper sanitization.

   It is a specific type of command injection, where untrusted input is included in a query or command. This vulnerability allows supplied data to be misinterpreted as executable commands, which can change the intended behavior of the SQL query and lead to unauthorized database operations.



2. **How to prevent SQL injection?**

   Answer:

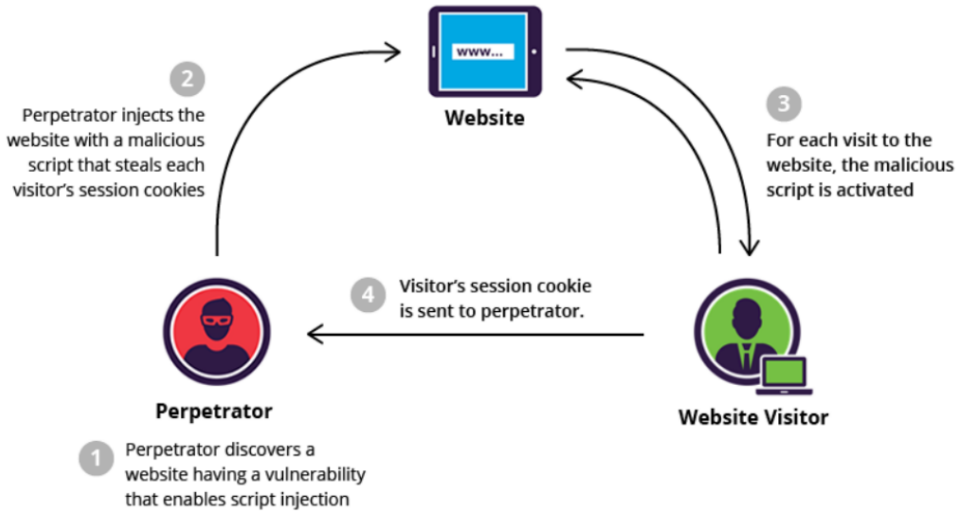
   - **Input validation:** Filter apostrophes, semicolons, percent symbols, hyphens, underscores, etc. any character that has special meanings. Check the data type (e.g., make sure input of a integer data is an integer).
   - **Whitelisting:** Blacklisting characters that doesn't work. For example, if we forget to filter out some characters, it could cause attacks. It could prevent valid input (e.g. username O'Brien) also. But allow only well-defined set of safe values, by set implicitly defined through regular expressions works fine.

3. **What is Cross Site Scripting (XSS)?**

   Answer: To successfully execute a XSS attack, a perpetrator has to locate a vulnerability in a web application and then inject malicious script into its server.

   A web application is vulnerable to cross site scripting attacks if it:

   - Stores user input without sanitizing, validating, or encoding it
   - Dynamically includes user data in its HTTP responses without sanitizing or validating it



4. **Write the consequences of the XSS attack.**
   Answer:
   - User accounts can be compromised
   - Trojan horse programs activated
   - Page content modified
   - Misleading users into surrendering their private info
   - Finally, session cookies could be revealed, enabling a perpetrator to impersonate valid users and abuse their private accounts.

5. **Write the types of XSS attacks.**
   Answer: There are two types of XSS attack:
   - **Stored XSS:** Stored XSS (or persistent XSS) is the more damaging of the two. It occurs when a malicious script is injected directly into a vulnerable web application.
   - **Reflected XSS:** Reflected XSS involves the reflecting of a malicious script off of a web application, onto a user's browser. The script is embedded into a link, and is only activated once that link is clicked on.

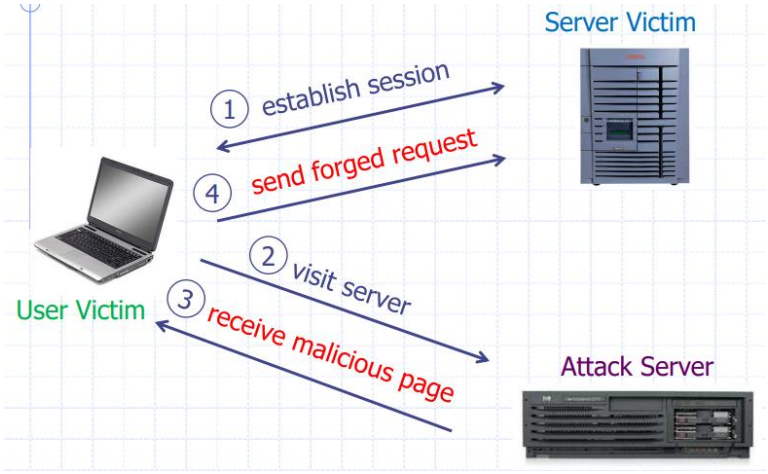
6. **What is Cross Site Request Forgery (CSRF)?**
   Answer: Cross Site Request Forgery (CSRF) is an attack vector that tricks a web browser into executing an unwanted action in an application to which a user is logged in.

   For example,
   - A typical GET request for a $100 bank transfer might look like:

   GET http://netbank.com/transfer.do?acct=PersonB&amount=$100 HTTP/1.1
   - A hacker can modify this script so it results in a $100 transfer to their own account.

   GET http://netbank.com/transfer.do?acct=AttackerA&amount=$100 HTTP/1.1
   - A bad actor can embed the request into an innocent looking hyperlink:

   Read more!



7. **Write the ways of CSRF Mitigation.**
   Answer:
   - Logging off web applications when not in use
   - Securing usernames and passwords
   - Not allowing browsers to remember passwords
   - Avoiding simultaneously browsing while logged into an application

8. **Write the recommendation for CSRF.**
   Answer:
   - **Login CSRF:** Use strict Referer validation to prevent CSRF attacks on login forms. Login requests are typically submitted over HTTPS, so they should be properly validated.
   - **HTTPS Websites:** Sensitive websites, such as banking sites, should use strict referer validation to protect against CSRF attacks and unauthorized requests.
   - **Other Security Measures:** Use secure frameworks like Ruby on Rails that correctly implement secret tokens to verify requests and prevent CSRF attacks.

Firewall

1. **What is firewall?**
   Answer: A firewall is an integrated collection of security measures designed to prevent unauthorized electronic access to a networked computer system. To protect private networks and individual machines from the dangers of the greater Internet, a firewall can be employed to filter incoming or outgoing traffic based on a predefined set of rules called firewall policies.

2. **Write working principle of firework.**
   Answer: Packets flowing through a firewall can have one of three outcomes:
   - **Accepted:** permitted through the firewall
   - **Dropped:** not allowed through with no indication of failure
   - **Rejected:** not allowed through, accompanied by an attempt to inform the source that the packet was rejected

   Policies used by the firewall to handle packets are based on several properties of the packets being inspected, including the protocol used, such as:
   - TCP or UDP
   - the source and destination IP addresses
   - the source and destination ports
   - the application-level payload of the packet (e.g., whether it contains a virus).

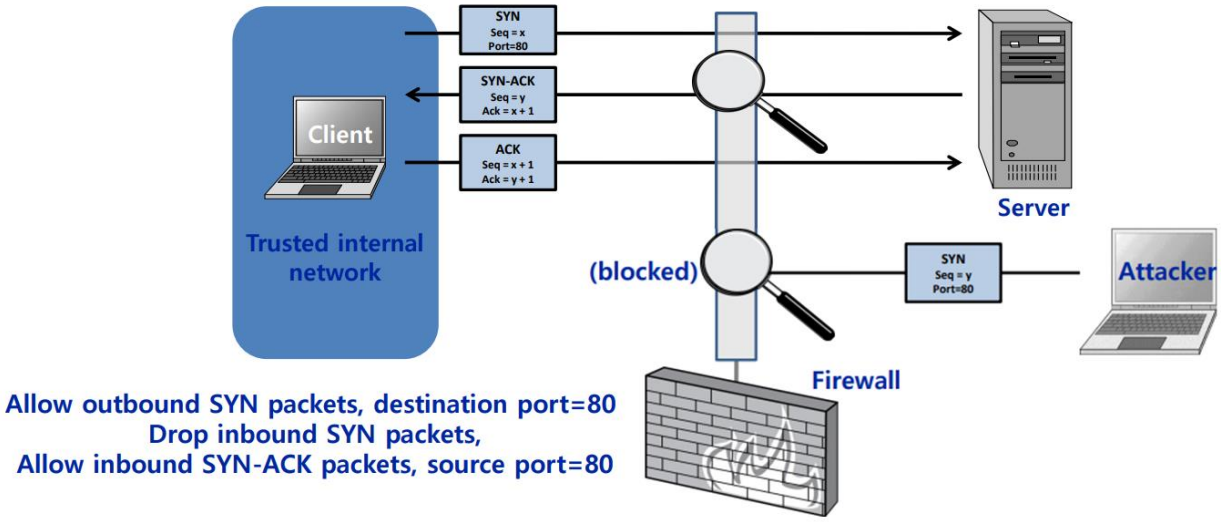
3. **What is Blacklists and Whitelists approach in Firewall?**
   Answer:
   - **Blacklist approach** (default-allow)
     - All packets are allowed through except those that fit the rules defined specifically in a blacklist.
     - **Pros:** flexible in ensuring that service to the internal network is not disrupted by the firewall
     - **Cons:** unexpected forms of malicious traffic could go through
   - **Whitelist approach** (default-deny)
     - Packets are dropped or rejected unless they are specifically allowed by the firewall
     - **Pros:** A safer approach to defining a firewall ruleset
     - **Cons:** must consider all possible legitimate traffic in rulesets

4. **Write the types of firewall.**
   Answer:
   - **Packet filters (stateless):** If a packet matches the packet filter's set of rules, the packet filter will drop or accept it.

- **Stateful filters:** It maintains records of all connections passing through it and can determine if a packet is either the start of a new connection, a part of an existing connection, or is an invalid packet.

5. **What is Stateless Firewall?**

   Answer: A stateless firewall doesn't maintain any remembered context (or "state") with respect to the packets it is processing. Instead, it treats each packet attempting to travel through it in isolation without considering packets that it has processed previously. Stateless firewalls may have to be fairly restrictive in order to prevent most attacks.



6. **What is Stateful Firewall?**

   Answer: Stateful firewalls can tell when packets are part of legitimate sessions originating within a trusted network. Stateful firewalls maintain tables containing information on each active connection, including the IP addresses, ports, and sequence numbers of packets. Using these tables, stateful firewalls can allow only inbound TCP packets that are in response to a connection initiated from within the internal network.

